# Vertrag zur Auftragsverarbeitung (AVV)

gemäß Art. 28 Datenschutz-Grundverordnung (DSGVO)

Stand: 28. Juli 2026 · Version 1.0

## Parteien

**Verantwortlicher** (nachfolgend „Kunde“):

Nachfolgend „Kunde“ genannt“

**Auftragsverarbeiter** (nachfolgend „Anbieter“):

Novax Digital GmbH
Schierholzstr. 27
30655 Hannover
vertreten durch: Philipp Polley, Christoph Pfad
Handelsregister: HRB 220589
E-Mail: info@versendio.de

Der Anbieter betreibt unter **versendio.de** die Plattform „Versendio“ zum Versand physischer Briefe (nachfolgend „Plattform“).

## Präambel

Der Kunde nutzt die Plattform, um Briefe an von ihm benannte Empfänger zu erstellen, zu drucken und postalisch zustellen zu lassen. Dabei verarbeitet der Anbieter personenbezogene Daten im Auftrag und nach Weisung des Kunden. Dieser Vertrag konkretisiert die datenschutzrechtlichen Pflichten der Parteien nach Art. 28 DSGVO. Er ist Bestandteil des Nutzungsvertrags über die Plattform (nachfolgend „Hauptvertrag“).

## § 1 Gegenstand und Dauer der Verarbeitung

1. Gegenstand der Verarbeitung ist die Erbringung der im Hauptvertrag vereinbarten Leistungen: Erstellung, Verwaltung, Druckaufbereitung und postalischer Versand von Briefen einschließlich Empfänger- und Kontaktverwaltung, Serienbrief-Funktionen, Versandautomatisierung und Statusverfolgung.
2. Die Dauer der Verarbeitung entspricht der Laufzeit des Hauptvertrags. § 9 (Löschung und Rückgabe) bleibt unberührt.

## § 2 Art, Zweck und Umfang der Verarbeitung

1. Art und Zweck der Verarbeitung, die Kategorien personenbezogener Daten und die Kategorien betroffener Personen ergeben sich aus **Anlage 1**.

2. Die Verarbeitung findet grundsätzlich in Mitgliedstaaten der Europäischen Union oder des Europäischen Wirtschaftsraums statt. Übermittlungen in Drittländer erfolgen nur unter den Voraussetzungen des § 6.

## § 3 Pflichten des Anbieters

1. Der Anbieter verarbeitet personenbezogene Daten ausschließlich auf dokumentierte Weisung des Kunden (§ 4), sofern er nicht durch das Recht der Union oder der Mitgliedstaaten zur Verarbeitung verpflichtet ist; in einem solchen Fall teilt der Anbieter dem Kunden diese rechtlichen Anforderungen vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.
2. Der Anbieter gewährleistet, dass sich die zur Verarbeitung befugten Personen zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.
3. Der Anbieter trifft alle gemäß Art. 32 DSGVO erforderlichen technischen und organisatorischen Maßnahmen (TOM). Die zum Vertragsschluss implementierten Maßnahmen sind in **Anlage 2** beschrieben. Der Anbieter darf die Maßnahmen an den Stand der Technik anpassen, sofern das vereinbarte Schutzniveau nicht unterschritten wird.
4. Der Anbieter unterstützt den Kunden mit geeigneten technischen und organisatorischen Maßnahmen dabei, Anfragen betroffener Personen nach Kapitel III der DSGVO zu beantworten (§ 7).
5. Der Anbieter unterstützt den Kunden unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Einhaltung der in Art. 32 bis 36 DSGVO genannten Pflichten (Sicherheit der Verarbeitung, Meldung von Verletzungen, Datenschutz-Folgenabschätzung, vorherige Konsultation).
6. Der Anbieter meldet dem Kunden Verletzungen des Schutzes personenbezogener Daten unverzüglich nach Bekanntwerden (§ 8).
7. Der Anbieter löscht oder gibt nach Abschluss der Erbringung der Verarbeitungsleistungen alle personenbezogenen Daten nach Wahl des Kunden zurück (§ 9), sofern nicht nach Unionsrecht oder dem Recht der Mitgliedstaaten eine Pflicht zur Speicherung besteht.
8. Ansprechpartner für Datenschutzfragen beim Anbieter: [Name/Funktion, E-Mail]. [Sofern gesetzlich erforderlich: Angaben zum Datenschutzbeauftragten.]

## § 4 Weisungsbefugnis des Kunden

1. Der Kunde erteilt Weisungen grundsätzlich über die Funktionen der Plattform (z. B. Auslösen, Terminieren und Stornieren von Sendungen, Anlegen und Löschen von Kontakten und Briefen, Konto- und Datenlöschung). Darüber hinausgehende Weisungen erfolgen in Textform an die in § 3 Abs. 8 genannte Adresse.
2. Der Anbieter informiert den Kunden unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen die DSGVO oder andere Datenschutzbestimmungen verstößt. Er ist berechtigt, die Ausführung der betreffenden Weisung bis zur Bestätigung oder Änderung durch den Kunden auszusetzen.

## § 5 Subauftragsverarbeiter

1. Der Kunde erteilt dem Anbieter die **allgemeine Genehmigung** zur Einschaltung der in **Anlage 3** aufgeführten Subauftragsverarbeiter.
2. Der Anbieter informiert den Kunden über beabsichtigte Änderungen (Hinzuziehung oder Ersetzung von Subauftragsverarbeitern) in Textform — mindestens **vier Wochen** vor Wirksamwerden. Der Kunde kann der Änderung aus wichtigem datenschutzrechtlichen Grund widersprechen. Kommt keine einvernehmliche Lösung zustande, ist jede Partei berechtigt, den Hauptvertrag zum Zeitpunkt des Wirksamwerdens der Änderung außerordentlich zu kündigen.
3. Der Anbieter erlegt jedem Subauftragsverarbeiter im Wege eines Vertrags dieselben Datenschutzpflichten auf, die in diesem Vertrag festgelegt sind, insbesondere hinreichende Garantien für geeignete technische und organisatorische Maßnahmen (Art. 28 Abs. 4 DSGVO). Kommt der Subauftragsverarbeiter seinen Pflichten nicht nach, haftet der Anbieter gegenüber dem Kunden für die Einhaltung der Pflichten des Subauftragsverarbeiters.
4. Keine Subauftragsverarbeitung im Sinne dieses Vertrags sind Leistungen, die der Anbieter in eigener datenschutzrechtlicher Verantwortung bezieht (siehe Hinweise in Anlage 3, Abschnitt B), sowie Integrationen, die der Kunde selbst mit eigenen Konten bei Drittanbietern verbindet (siehe Anlage 3, Abschnitt C).

## § 6 Verarbeitung in Drittländern

1. Eine Verarbeitung in Drittländern (außerhalb EU/EWR) findet nur statt, wenn die Voraussetzungen der Art. 44 ff. DSGVO erfüllt sind — insbesondere auf Grundlage eines Angemessenheitsbeschlusses (z. B. EU-US Data Privacy Framework) oder der EU-Standardvertragsklauseln (SCC) einschließlich erforderlicher zusätzlicher Maßnahmen.
2. Die je Subauftragsverarbeiter einschlägigen Transfermechanismen sind in **Anlage 3** ausgewiesen.

## § 7 Unterstützung bei Betroffenenrechten

1. Der Kunde kann Auskunfts-, Berichtigungs- und Löschbegehren zu den im Auftrag verarbeiteten Daten weitgehend selbst über die Plattform erfüllen (Bearbeiten und Löschen von Kontakten, Briefen und Sendungshistorie; maschinenlesbarer Datenexport; Kontolöschung).
2. Wendet sich eine betroffene Person unmittelbar an den Anbieter, leitet dieser das Ersuchen unverzüglich an den Kunden weiter und beantwortet es nicht selbst, sofern keine gesetzliche Pflicht besteht.

## § 8 Meldung von Datenschutzverletzungen

1. Der Anbieter meldet dem Kunden jede Verletzung des Schutzes personenbezogener Daten, die im Auftrag verarbeitete Daten betrifft, **unverzüglich**, spätestens jedoch innerhalb von 48 Stunden nach Bekanntwerden, an die im Kundenkonto hinterlegte E-Mail-Adresse.
2. Die Meldung enthält, soweit bekannt, die Angaben nach Art. 33 Abs. 3 DSGVO (Art der Verletzung, Kategorien und ungefähre Zahl der Betroffenen und Datensätze, wahrscheinliche Folgen, ergriffene und vorgeschlagene Maßnahmen).

3. Die Meldung an die Aufsichtsbehörde und die Benachrichtigung betroffener Personen (Art. 33, 34 DSGVO) obliegen dem Kunden; der Anbieter unterstützt hierbei.

## § 9 Löschung und Rückgabe

1. Während der Vertragslaufzeit kann der Kunde die im Auftrag verarbeiteten Daten jederzeit über die Plattform einsehen, exportieren und löschen. Brief-Dokumente werden zudem nach Ablauf der in der Plattform konfigurierten Aufbewahrungsfrist automatisiert gelöscht.
2. Nach Beendigung des Hauptvertrags — oder auf Anforderung des Kunden über die Kontolöschungs-Funktion — löscht der Anbieter alle im Auftrag verarbeiteten personenbezogenen Daten, sofern keine gesetzlichen Aufbewahrungspflichten entgegenstehen (insbesondere handels- und steuerrechtliche Pflichten für Abrechnungsdaten). Buchungs- und Abrechnungsdaten werden in diesem Fall für die Dauer der gesetzlichen Fristen gesperrt und anschließend gelöscht.
3. Auf Wunsch stellt der Anbieter dem Kunden vor der Löschung einen Export der Daten in einem strukturierten, gängigen und maschinenlesbaren Format bereit (in der Plattform integrierte Export-Funktion).

## § 10 Nachweise und Kontrollen

1. Der Anbieter stellt dem Kunden alle erforderlichen Informationen zum Nachweis der Einhaltung der in Art. 28 DSGVO niedergelegten Pflichten zur Verfügung — insbesondere diese Vereinbarung, die TOM-Beschreibung (Anlage 2) sowie vorhandene Nachweise und Zertifizierungen der Subauftragsverarbeiter.
2. Der Kunde ist berechtigt, die Einhaltung dieses Vertrags zu überprüfen — vorrangig durch Einholung von Selbstauskünften und vorhandenen Prüfnachweisen, bei berechtigtem Anlass auch durch Inspektionen. Inspektionen erfolgen nach angemessener Vorankündigung (mindestens 14 Kalendertage), zu üblichen Geschäftszeiten, ohne Störung des Betriebsablaufs und unter Wahrung von Geschäftsgeheimnissen; für Rechenzentren der Subauftragsverarbeiter gelten deren Prüf- und Nachweisverfahren.

## § 11 Haftung

Für die Haftung der Parteien gelten Art. 82 DSGVO sowie die Haftungsregelungen des Hauptvertrags.

## § 12 Laufzeit und Kündigung

Dieser Vertrag beginnt mit Einbeziehung in den Hauptvertrag und endet mit dessen Beendigung. Eine gesonderte Kündigung dieses Vertrags ist ausgeschlossen; das Recht zur außerordentlichen Kündigung aus wichtigem Grund bleibt unberührt.

## § 13 Schlussbestimmungen

1. Änderungen und Ergänzungen dieses Vertrags bedürfen der Textform.
2. Bei Widersprüchen zwischen diesem Vertrag und dem Hauptvertrag gehen die Regelungen dieses Vertrags in datenschutzrechtlichen Fragen vor.

3. Es gilt das Recht der Bundesrepublik Deutschland.
4. Sollten einzelne Bestimmungen unwirksam sein, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.

## Anlage 1 — Gegenstand der Verarbeitung

### Art und Zweck der Verarbeitung

- Erstellung, Bearbeitung und Speicherung von Briefdokumenten (Editor, Upload, Serienbriefe mit Platzhaltern)
- Verwaltung von Kontakten und Empfängerlisten (inkl. CSV-Import)
- Druckaufbereitung (PDF-Erzeugung/-Normalisierung, Adressierung) und Übergabe an den Druck- und Zustelldienstleister
- Versandautomatisierung (zeitversetzter Versand, wiederkehrende Versandregeln)
- Statusverfolgung und Sendungshistorie
- Optional, nur bei aktiver Nutzung durch den Kunden: KI-gestützte Brieftexterstellung

### Kategorien betroffener Personen

- Empfänger der Briefe des Kunden (z. B. Kunden, Interessenten, Mitglieder, Geschäftspartner, Mitarbeiter des Kunden)
- Ansprechpartner und Nutzer des Kunden (Kontoinhaber, eingeladene Nutzer)
- Bei Whitelabel-Nutzung: Endkunden des Kunden

### Kategorien personenbezogener Daten

- Adress- und Kontaktdaten der Empfänger (Anrede, Name, Firma, Anschrift)
- Briefinhalte einschließlich aller darin enthaltenen personenbezogenen Daten; Art und Sensibilität bestimmt allein der Kunde durch den Inhalt seiner Briefe
- Sendungsmetadaten (Empfänger, Seitenzahl, Versandoptionen, Zustellstatus)
- Konto- und Nutzungsdaten des Kunden (Name, E-Mail, Absenderadressen)

### Besondere Kategorien (Art. 9 DSGVO)

Die Plattform ist nicht auf besondere Kategorien personenbezogener Daten ausgerichtet. Enthalten Briefinhalte des Kunden solche Daten (z. B. Gesundheitsdaten in Arztbriefen), bleibt der Kunde für die Rechtsgrundlage verantwortlich; die Verarbeitung erfolgt ausschließlich zur Erbringung der Versandleistung.

versendio

# Anlage 2 — Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

## 1. Zugangs- und Zugriffskontrolle

- Zugriff auf die Plattform nur mit persönlichem Konto (E-Mail-Verifizierung); Passwörter werden ausschließlich als kryptografische Hashes gespeichert
- Strikte Mandantentrennung auf Datenbankebene: Row-Level-Security-Richtlinien auf allen Tabellen; jeder Nutzer kann ausschließlich eigene Datensätze abrufen
- Briefdokumente liegen in privaten Storage-Buckets; Auslieferung ausschließlich über kurzlebige signierte URLs, niemals öffentlich
- Administrative Systemzugriffe (Service-Schlüssel) existieren nur serverseitig und werden nicht an Clients ausgeliefert; Admin-Funktionen erfordern die Admin-Rolle und ein aktives Konto

## 2. Übertragungskontrolle

- Transportverschlüsselung (TLS) für sämtliche Verbindungen: Browser ↔ Plattform, Plattform ↔ Datenbank/Storage, Plattform ↔ Subauftragsverarbeiter
- Übergabe an den Druckdienstleister ausschließlich über dessen authentifizierte API (tokenbasiert, kurzlebige Zugangstoken)

## 3. Eingabe- und Auftragskontrolle

- Serverseitige Validierung aller Eingaben; Statusänderungen an Sendungen werden als Ereignisprotokoll gespeichert (Nachvollziehbarkeit)
- Guthaben-/Abrechnungsbewegungen in einem nur-anfügenden Buchungsjournal (revisionssichere Nachvollziehbarkeit von Buchungen und Erstattungen)
- Adress- und Briefdaten werden nicht im Klartext in Anwendungs-Logs geschrieben
- Weisungsgebundene Verarbeitung; Subauftragsverarbeiter sind vertraglich gebunden (§ 5)

## 4. Verfügbarkeitskontrolle und Belastbarkeit

- Betrieb in professionellen Cloud-Rechenzentren mit redundanter Infrastruktur
- Automatisierte Datenbank-Backups durch den Datenbank-Dienstleister; Wiederherstellungsverfahren dokumentiert
- Idempotente, wiederholbare Verarbeitungsschritte im Versandprozess verhindern Doppelversand und Datenverlust bei Störungen (Duplikatschutz, Wiederholung mit Backoff)

## 5. Verschlüsselung ruhender Daten

- Datenbank und Objektspeicher sind serverseitig verschlüsselt (AES-256 auf Infrastrukturebene der Dienstleister); Zugangsdaten zu Drittsystemen werden zusätzlich anwendungsseitig verschlüsselt gespeichert

## 6. Trennungskontrolle

- Mandantentrennung per Row-Level-Security (siehe 1.)

– Trennung von Produktiv- und Testumgebung; Testsendungen sind gekennzeichnet und administrativ beschränkt

### 7. Löschkonzept

– Nutzer-Selbstbedienung: Löschen von Kontakten, Briefen und Konto inklusive automatischer Anonymisierung/Löschung verknüpfter Daten
– Automatische Löschung von Briefdokumenten nach konfigurierter Aufbewahrungsfrist
– Datenexport in maschinenlesbarem Format vor Löschung möglich

## Anlage 3 — Subauftragsverarbeiter

### A. Genehmigte Subauftragsverarbeiter

| Nr. | Unternehmen | Leistung | Ort der Verarbeitung | Transfermechanismus |
|---|---|---|---|---|
| 1 | Supabase, Inc., 970 Toa Payoh North #07-04, Singapur / USA | Datenbank, Authentifizierung, Dateispeicher (Briefdokumente, Kontakte) | [EU-Region gemäß Projektkonfiguration, z. B. Frankfurt/DE — zu verifizieren] | Verarbeitung in der EU; für Support-Zugriffe: EU-Standardvertragsklauseln |
| 2 | Vercel Inc., 440 N Barranca Ave #4133, Covina, CA 91723, USA | Hosting und Ausführung der Anwendung (Serverless-Infrastruktur, CDN) | EU [Deployment-Region zu verifizieren]; Unternehmenssitz USA | EU-US Data Privacy Framework, EU-Standardvertragsklauseln |
| 3 | Deutsche Post AG, Charles-de-Gaulle-Str. 20, 53113 Bonn (E-POSTBUSINESS) [exakte Vertragspartei gemäß E-POST-Vertrag verifizieren] | Druck, Kuvertierung, Frankierung und postalische Zustellung der Briefe | Deutschland | Nicht erforderlich (Verarbeitung in Deutschland) |
| 4 | Anthropic, PBC, 500 Howard Street, San Francisco, CA 94105, USA | KI-gestützte Brieftexterstellung — **nur bei aktiver Nutzung der KI-Entwurfsfunktion durch den Kunden**; Eingaben und Ergebnisse werden nicht protokolliert oder dauerhaft gespeichert | USA | EU-US Data Privacy Framework, EU-Standardvertragsklauseln |

**Hinweis zu Nr. 3:** Die postalische Beförderung selbst unterliegt zudem dem Postgeheimnis (§ 39 PostG).

### B. Dienstleister in eigener Verantwortung des Anbieters (keine Subauftragsverarbeiter)

Folgende Dienstleister verarbeiten keine Auftragsdaten des Kunden (keine Empfängerdaten, keine Briefinhalte), sondern ausschließlich Daten, die der Anbieter als eigener Verantwortlicher verarbeitet (Vertrags- und Abrechnungsdaten des Kunden). Sie werden aus Transparenzgründen genannt:

– **Stripe Payments Europe, Ltd.** (Dublin, Irland) — Zahlungsabwicklung beim Guthaben-Erwerb

– **Resend, Inc.** (USA) — Versand von Konto- und Transaktions-E-Mails an den Kunden (EU-Standardvertragsklauseln)

### C. Vom Kunden aktivierte Integrationen (keine Subauftragsverarbeiter)

Verbindet der Kunde eigene Konten bei Drittanbietern mit der Plattform (derzeit möglich: **Canva** für Design-Import, **Moco** für Kontakt-/CRM-Synchronisation), erfolgt dies auf Veranlassung und in Verantwortung des Kunden im Verhältnis zu seinem jeweiligen Anbieter. Die Plattform greift dabei ausschließlich mit den vom Kunden hinterlegten Zugangsdaten auf dessen eigenes Drittanbieter-Konto zu.

## Unterschriften

| | |
|---|---|
| _____ | _____ |
| Datum, Unterschrift Kunde | Datum, Unterschrift Plattform |